

Task1.1P and 1.2P Start Activity

Threat modeling is a systematic approach used to identify and analyze potential threats and vulnerabilities in a system, application, or network. It helps organizations understand their assets, potential risks, and prioritize security efforts to effectively mitigate threats. Let's see a few examples in this workshop. In this workshop you will explore first some of the secure coding principles and threat modelling.

Secure coding principles

Read some of the coding principles given here.

<https://devguide.owasp.org/en/02-foundations/03-security-principles/>

[Principles of security - OWASP Developer Guide](#)

Apply these principles for the following scenarios:

Scenario	Secure coding principle violated/applied
Use a Network firewall, Web Application firewall, encryption and validations	Defense in depth
Erroneous code in the remote desktop application allows users to bypass authentication when exception occurs	Fail safe not applied correctly
Customer login provides read-only access to the product administration page, which should only be accessible to product admins.	
In a large organization, a single admin has access to all the administrative functions of the web application.	

Threat modelling

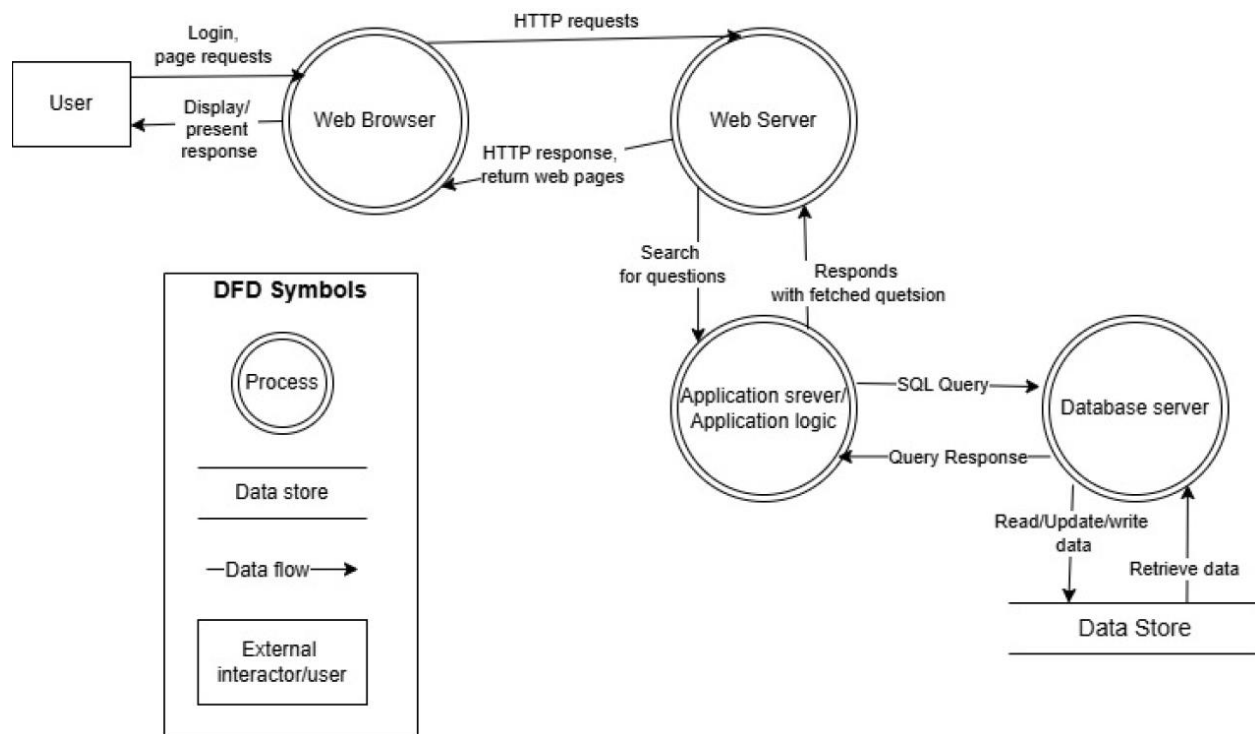
Description of the application: As a running example and recurrent goal throughout this course we will attempt to develop a web application that does the following. A lecturer submits questions and answers to a repository. Questions should have annotations defining their area of knowledge. A student creates mock exams on a particular area of knowledge based on existing questions.



Step 1: identify and understand the system architecture and the potential users.

Users here are: Student, Lecturer and possibly an administrator

Step2: Consider a sample application access scenario to draw the DFD: Student creates a mock exam on a particular area of knowledge based on questions in the database. Students first access the web app via the web-browser and login to the application and queries the database for existing questions for a particular area of knowledge. Then the student selects the relevant questions and creates a mock exam which is stored in the database.



The above diagram shows a simple DFD for the student access requests for specific area of knowledge.

Trust boundaries in a Data Flow Diagram (DFD) represent the points where data transitions from a trusted zone to an untrusted zone. It indicates a change in the level of trustworthiness or security context within the system. Trust boundaries are crucial for understanding and defining the security controls and access privileges required to protect sensitive data and mitigate risks.

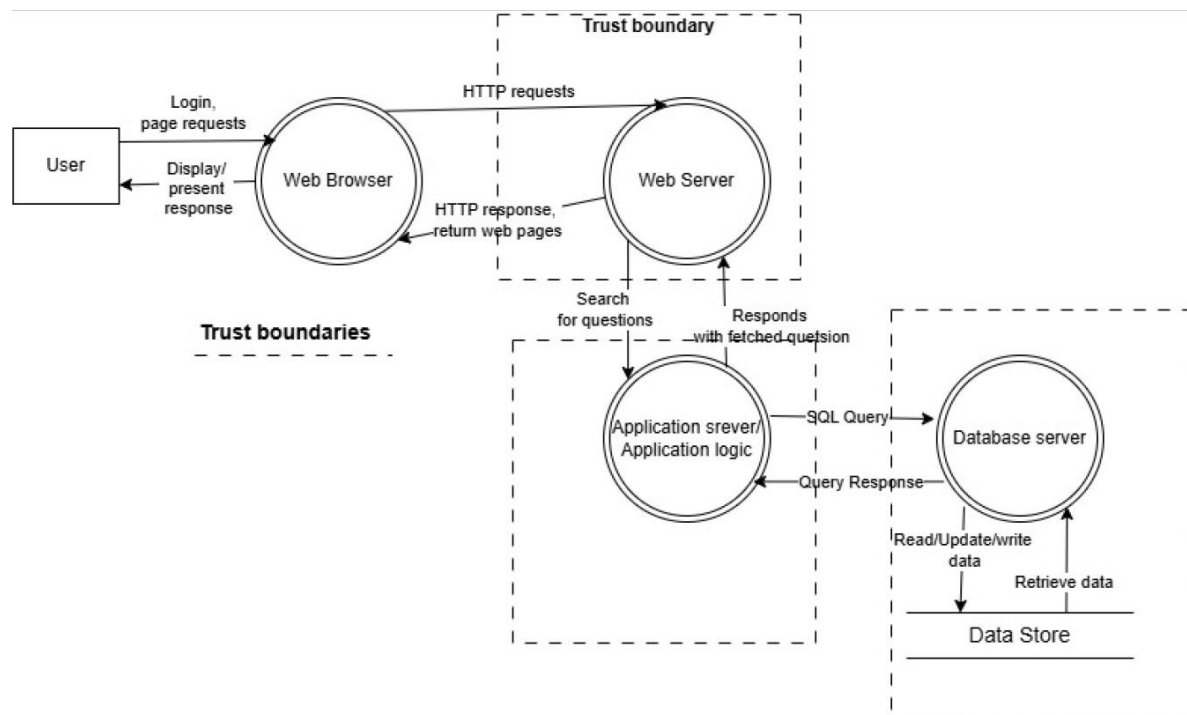
In a DFD, trust boundaries are typically represented by dashed lines or other visual indicators. These boundaries separate different components or external entities based on their level of trust. Here are a few examples of trust boundaries in a DFD:

- **Web server Boundary:** The boundary between the Web server and user's browser represents a trust boundary. Data flows between an untrusted zone and a semi-trusted zone in both directions.
- **Application server Boundary:** The boundary between the web server and application server represents a trust boundary. Data flows between a semi-trusted zone and a restricted trust zone in both directions.

- **Database Boundary:** The boundary between the application server and the database server represents a trust boundary. Data flows between a restricted trust zone and the lowest level of internal network (fully restricted) trust zone in both directions.

Identifying trust boundaries is essential for defining security requirements, access controls, and data protection measures within a system. By understanding where trust boundaries exist, organizations can implement appropriate security controls and establish effective security mechanisms to protect sensitive data and prevent unauthorized access or data breaches at the boundary points.

Now we can draw the trust boundaries based on these conditions where data transitions from trusted to untrusted zones.



Here, the user accesses the web application on their computer, with the web browser forming part of the client environment. Through the web browser, the user accesses the front-end of the web application hosted on the web server. The web server hosts the front-end logic, and all user views are handled by this layer. The application logic for business functions is separated and placed on an application server. When a request is received by the web server, it presents a search page where the student can enter keywords for a specific area of knowledge. Once the application logic receives this input, it retrieves the matching questions from the database. The database may be located on a separate network.

Applying STRIDE threat model on DFD elements:

Each DFD element can be susceptible to multiple threats. An example threat list to DFD elements is presented in the following table.

DFD Elements	Spoofing	Tampering	Repudiation	Information Disclosure	Denial of Service	Elevation of Privilege
Data Flows		X		X	X	
Data Stores		X		X	X	
Processes	X	X	X	X	X	X
Interactors /External entities End points (people, external services)	X		X			

Let's brainstorm the threats on the DFD elements and the possible mitigation strategies using the STRIDE threat modelling technique.

Threats	DFD element	Examples: Description of Threat events/ threat scenarios for the DFD element and impact of the threats	Mitigation Techniques
Spoofing	External entities/ interactor	Identity spoofing – malicious users will spoof the identity of students, lecturers, or admins to gain unauthorized access to the webapp. The credential can be achieved by social engineering technique, password guessing, dictionary and brute -forcing attack, dumpster diving (printer's trash bin), shoulder surfing. Attacker may attract user to download a malicious attachment by email, once clicked that can install keylogger to steal credential. If the authentication is federated, login failure possible from inappropriate implementation of SSO protocols (e.g. OAuth, SAML vulnerabilities for more details), The impact could be serious. The attacker can gain access to the server using a non-administrative account and perform privilege escalation attack to gain higher administrative privileges. This will allow to access sensitive information, delete files, install malicious programs, can poison the DNS cache, create an indirect point to issue commands	Using strong authentication techniques (MFA etc.) Do not use clear text protocol or protocols with weak encryption, strong password policies (avoid storing password in an unsecured location, do not use system default's password, short duration of password change, enable account lockout), train employees,

		to attack other hosts in the network.	Use SSL certificates to verify the identity of web servers.
Tampering	Process	Failure of input validation or improper input validation can cause process to crash, excessive memory consumption by the process. Buffer overflows may happen due to lack of input validation which also can cause arbitrary malicious code to be executed by the process.	Use proper input validation using regular expression, both client side and server side validation, file upload validation.
Repudiation			
Information disclosure			
Denial service			
Elevation of Privileges			

You can use the threat tree (Appendix B) and explanation of threat mentioned in the following book to learn different types of threat on DFD elements and how that attack can be implemented.

Shostack, Adam. Threat Modeling : Designing for Security, John Wiley & Sons, Incorporated, 2014.

For more reference on threat scenarios, continue your own research using online resources below:

1. [CAPEC - Common Attack Pattern Enumeration and Classification \(CAPEC™\)](https://capec.mitre.org/)
2. Search in the [CVE: Common Vulnerabilities and Exposures](https://www.cve.org/), website: <https://www.cve.org/>, e.g type in the search box – ‘spoofing a process’. Search result will show many CVEs (e.g. CVE-2026-42013), search using words ‘process information disclosure’-- search result will show many CVEs e.g. CVE-2026-7261, Data base denial of service: CVE-2025-44203
3. CMU, Software Engineering Institute, CERT Coordination Center, Search in <https://www.kb.cert.org/vuls/search/>
4. [MITRE ATT&CK®](https://attack.mitre.org/) <https://attack.mitre.org/>
5. [OWASP Top Ten | OWASP Foundation](#)
6. SANS software error: [Top 25 Software Errors | SANS Institute](https://www.sans.org/top25-software-errors/), <https://www.sans.org/top25-software-errors/>